

RealtouchHR Billing & Subscription Modification

Feature Specification and Codex/Developer Prompt

For Starter, Professional and Enterprise Plans; Payslip Pay-Per-Download; UKVI Compliance Scanner Usage Limits; Add-ons; Stripe Billing; Production-Ready Implementation

Purpose: This document instructs the developer/Codex to first audit the existing Billing & Subscription implementation, then update the pricing, feature-gating, UKVI Compliance Scanner limits, payslip preview/download payment workflow, add-ons and production readiness controls for the RealtouchHR application.

Document Item	Details
Product	RealtouchHR
Module	Billing & Subscription, Plans, Add-ons, Payslip Download Payments, UKVI Compliance Scanner
Primary Audience	Software developer, Codex, product owner, QA tester
Implementation Style	Audit-first, then build, test and production-harden
Payment Assumption	Stripe test keys currently active; production must use live Stripe keys and webhooks before go-live

1. Executive Summary

The Billing & Subscription module must be modified so that every company workspace has clear plan pricing, accurate feature entitlement, automated access control, usage limits and payment handling. The system must prevent unpaid download actions while allowing preview-only access where required.

The new billing configuration is:

Plan	Monthly Price	Employee Limit	UKVI Compliance Scanner	Main Positioning
Starter	GBP 29 / month	Up to 10 employees	Enabled, but limited to 2 scans per month. Must also show upgrade/add-on path to Professional.	Entry plan for small employers with core HR and compliance scanning access.
Professional	GBP 39 / month	Up to 50 employees	Enabled, limited to 2 scans per month.	Best value plan with payroll, RTI and UKVI compliance

				features.
Enterprise	GBP 129 / month	Unlimited employees	Enabled, limited to 2 scans per month unless later overridden by enterprise contract.	Full options, multi-entity and advanced controls.

2. Required Pricing and Feature Changes

Current Item	Required Change
Starter currently displayed as GBP 39/month	Change to GBP 29/month.
Professional currently displayed as GBP 59/month	Change to GBP 39/month.
Enterprise currently displayed as GBP 149/month	Change to GBP 129/month.
UKVI Compliance Scanner visibility	Enable on Starter, Professional and Enterprise with monthly usage limit.
UKVI Compliance Scanner upgrade path	Starter users should see UKVI Scanner as available and also see an add-on/upgrade prompt encouraging upgrade to Professional.
Payslip download	Preview is free. Download requires GBP 5 payment per payslip download.
UKVI scanner report download	Report can be downloaded in both Word and PDF formats after a scan is completed.
Scanner monthly limit	Each company can run UKVI Compliance Scanner only twice per billing month.
Billing and feature gating	Must be enforced on frontend, backend, API and database level.

3. Plan Configuration Matrix

Feature	Starter - GBP 29	Professional - GBP 39	Enterprise - GBP 129
Employee limit	10	50	Unlimited
Basic HR features	Included	Included	Included
Payroll processing	Included	Included	Included
HMRC RTI submissions	Optional/configurable if available in codebase; ensure plan logic is clear	Included	Included
UKVI Compliance Scanner	Included with 2 scans/month; show upgrade/add-on prompt	Included with 2 scans/month	Included with 2 scans/month; full enterprise options
UKVI report download	Word/PDF after scan completion	Word/PDF after scan completion	Word/PDF after scan completion
Payslip preview	Free preview	Free preview	Free preview
Payslip download	GBP 5 per payslip download	GBP 5 per payslip download	GBP 5 per payslip download
Multi-entity support	Not included	Not included unless	Included

		added	
SSO/SCIM	Not included	Not included unless added	Included
Custom integrations	Not included	Not included unless added	Included
Dedicated support	Not included	Priority support only if configured	Included

4. Payslip Preview and Paid Download Workflow

All plans must allow users with valid permission to preview payslips inside the application. However, no payslip file should be downloadable until a GBP 5 payment is completed for that specific payslip download transaction.

Step	Required Behaviour
1. User opens payslip	System shows preview-only payslip view. Download button is visible but locked/payment-gated.
2. User clicks Download	System shows payment prompt: "Payslip download costs GBP 5. Preview is free."
3. System creates payment session	Backend creates Stripe Checkout/PaymentIntent for GBP 5, linked to company_id, employee_id, payslip_id and requesting user_id.
4. User pays	Stripe processes payment.
5. Webhook confirms payment	Backend receives verified webhook and marks payslip download entitlement as paid.
6. Immediate download	After payment success, system automatically starts the payslip download or displays "Download now".
7. Audit log	Log who requested download, payslip, company, amount paid, payment reference, timestamp and file format.

5. Payslip Download Rules

Rule	Implementation Requirement
Preview must not expose raw file URL	Render preview using secure route, signed temporary access, watermarked preview or protected PDF viewer.
Download must be server-authorised	Backend must verify paid entitlement before returning the file. Frontend checks alone are not enough.
One payment per payslip download event	A GBP 5 payment should unlock the requested payslip download for that transaction. Store policy clearly in code/config.
Permission still required	Payment does not override role permissions. User must have permission to access that payslip.
No bypass through direct URL	Direct API/file URL access must return 403 unless paid entitlement and permission exist.

Refund handling	If refunded or payment fails, entitlement must be revoked or marked invalid according to product policy.
-----------------	--

6. UKVI Compliance Scanner Rules

The UKVI Compliance Scanner is enabled across all new plans but must be usage-limited to two scan runs per company per billing month. Reports must be previewable and downloadable in Word and PDF formats.

Requirement	Details
Monthly scan limit	Maximum 2 UKVI Compliance Scanner runs per company per billing month.
Usage counter	Track scan count by company_id and billing_period_start/end.
Attempt beyond limit	Block the scan and show: “You have used your 2 UKVI Compliance Scanner runs for this billing month.”
Report output	Each completed scan should generate preview data and exportable PDF/DOCX report.
Report archive	Store report metadata and generated files securely by company.
Alerts	If compliance gaps are found, create alerts in UKVI Compliance > Alerts and Dashboard alerts.
Starter upgrade prompt	Starter should see a prompt explaining that Professional includes a broader compliance package. The add-on/upgrade route should move them to Professional.

7. Add-on and Upgrade Behaviour

The product owner request says UKVI Compliance Scanner should also appear as an add-on for the Starter plan so that Starter can choose it at any point to upgrade to Professional. Because the scanner is enabled in Starter, the recommended implementation is to treat this as an upgrade CTA rather than a separate duplicate scanner entitlement.

Scenario	Required Behaviour
Starter user views add-ons	Show “Upgrade to Professional for enhanced UKVI Compliance package” rather than creating duplicate scanner access.
Starter clicks UKVI Scanner add-on	Redirect to plan upgrade flow to Professional at GBP 39/month, prorated if Stripe supports it.
Professional user views add-ons	Do not show scanner upgrade; it is already included.
Enterprise user views add-ons	Do not show scanner upgrade; it is already included.
Old standalone UKVI scanner add-on exists	Audit it and either migrate it to Professional

	upgrade CTA or remove safely after checking subscriptions.
--	--

8. Required Backend/Data Model Changes

Data Area	Recommended Fields / Notes
plans	id, name, price_gbp_monthly, stripe_price_id, employee_limit, active, features_json
company_subscriptions	company_id, plan_id, stripe_customer_id, stripe_subscription_id, status, current_period_start, current_period_end
feature_entitlements	company_id, feature_key, enabled, source(plan/addon/manual), limit_value, limit_period
ukvi_scan_usage	company_id, billing_period_start, billing_period_end, scans_used, last_scan_at
ukvi_scan_reports	company_id, scan_id, status, score, risk_level, pdf_file_path, docx_file_path, created_by, created_at
payslip_download_payments	company_id, employee_id, payslip_id, user_id, stripe_payment_intent_id, amount_gbp, status, paid_at, downloaded_at
billing_transactions	company_id, user_id, type, amount, currency, status, stripe_reference, metadata_json
audit_logs	Log plan changes, payment events, scanner usage, downloads and feature entitlement changes.

9. Required API/Service Behaviour

Endpoint / Service	Required Behaviour
GET /api/billing/plans	Return updated plan prices and plan features.
POST /api/billing/subscribe	Create or update Stripe subscription for selected plan.
POST /api/billing/upgrade-to-professional	Upgrade Starter to Professional and update entitlement.
GET /api/billing/entitlements	Return feature access and usage limits for current company.
POST /api/payslips/:id/download-payment	Create GBP 5 Stripe payment session for the payslip download.
GET /api/payslips/:id/preview	Allow preview if user has payslip view permission.
GET /api/payslips/:id/download	Allow download only if payment entitlement exists and permission passes.
POST /api/ukvi/scans/run	Check subscription, feature entitlement and monthly usage limit before running scan.
GET /api/ukvi/scans/:id/report/preview	Show report preview if permitted.
GET /api/ukvi/scans/:id/report/download?format=pdf docx	Download report in selected format.

POST /api/stripe/webhook	Verify signature and update subscriptions/payment entitlements based on events.
--------------------------	---

10. Frontend/UI Requirements

Screen	Required UI Change
Billing & Subscription page	Display Starter GBP 29/month, Professional GBP 39/month, Enterprise GBP 129/month.
Plan cards	Update bullet points and remove contradictory pricing/copy.
Starter card	Show UKVI Compliance Scanner included with 2 scans/month and upgrade CTA to Professional.
Professional card	Show UKVI Compliance Scanner included with 2 scans/month.
Enterprise card	Show full options and UKVI Compliance Scanner included.
Payslip screen	Preview button free; Download button shows GBP 5 payment requirement.
UKVI Scanner screen	Show “2 scans per billing month” usage meter, e.g. 1/2 scans used.
Limit reached state	Disable run scan button and show upgrade/contact message.
Reports page	Offer “Preview”, “Download PDF”, “Download Word”.

11. Security, Permissions and Compliance Controls

Control	Requirement
Server-side enforcement	All plan, feature and payment checks must happen in backend.
Tenant isolation	A company must never access another company’s subscriptions, scans, payslips or reports.
Role permissions	Only permitted users can preview/download payslips or run UKVI scans.
Stripe webhook verification	Use signed webhook verification. Do not trust frontend success redirect alone.
Secure file delivery	Use signed URLs or authenticated streaming; no public payslip/report URLs.
Audit logs	Log billing changes, payments, downloads, scans and report downloads.
Environment safety	Test mode and live mode must be separated; no test keys in production.
Idempotency	Stripe events and payment sessions must be idempotent to avoid duplicate entitlements.

12. Audit-First Implementation Checklist

Before making changes, the developer/Codex must audit the current implementation and produce a short findings summary.

- Identify where plan pricing is hard-coded or stored in database/config.
- Identify existing Stripe products, prices, checkout sessions, customer portal and webhook handlers.
- Identify whether feature flags/entitlements already exist for UKVI Compliance Scanner, payslip downloads, RTI, payroll and enterprise features.
- Identify current payslip generation, preview and download routes.
- Check whether payslip downloads can currently be bypassed through direct file URL/API route.
- Identify current UKVI Compliance Scanner scan-run logic, report generation and download logic.
- Check whether UKVI scan usage limits already exist.
- Identify billing transaction history implementation and audit logging.
- Identify existing tests for billing, subscription, webhooks, payslips and UKVI scanner.
- Confirm whether the UI is using live plan data from backend or duplicated frontend constants.

13. Production Readiness Acceptance Criteria

- Billing page shows GBP 29 Starter, GBP 39 Professional and GBP 129 Enterprise.
- Plan features are accurate and consistent across UI, backend and Stripe configuration.
- Starter, Professional and Enterprise can access UKVI Compliance Scanner subject to 2 scans/month limit.
- UKVI Scanner usage counter resets according to the company billing period.
- Trying to run a third scan in the same billing month is blocked and logged.
- UKVI reports can be previewed and downloaded in PDF and Word formats.
- Payslip preview is available without payment to authorised users.
- Payslip download prompts for GBP 5 payment on every download request according to product policy.
- After successful payment, the payslip download starts immediately or a secure download button is shown.
- Failed or cancelled payment does not unlock payslip download.
- Direct payslip file URLs or API download attempts are blocked unless payment entitlement exists.
- Stripe webhook signature verification is implemented and tested.
- Billing transaction history records subscriptions, upgrades, payslip payments and scanner/report actions where relevant.
- Audit log records all sensitive billing, payslip and scanner actions.
- Tests pass for unit, integration, payment, webhook, permission and tenant-isolation scenarios.

14. Comprehensive Codex / Developer Prompt

Copy and paste the following prompt into Codex or send it to the software developer.

You are working on the RealtouchHR application. I need you to audit and then modify the Billing & Subscription module, payslip download workflow and UKVI Compliance Scanner entitlement/usage logic. Do not assume the existing implementation is complete. First inspect the codebase, routes, APIs, database models, Stripe integration, feature flags, UI constants and tests. Then implement the required production-ready changes.

BUSINESS REQUIREMENTS**1. Update the subscription pricing:**

- Starter: GBP 29/month.
- Professional: GBP 39/month.
- Enterprise: GBP 129/month.

2. Plan entitlements:

- Starter: up to 10 employees, core HR features, payroll processing, UKVI Compliance Scanner enabled with 2 scan runs per billing month.
- Professional: up to 50 employees, full HR suite, payroll + RTI submissions if available in the product, UKVI Compliance Scanner enabled with 2 scan runs per billing month, priority support where configured.
- Enterprise: unlimited employees, all features included, multi-entity support, SCIM/SAML SSO where available, dedicated support, custom integrations, UKVI Compliance Scanner enabled with 2 scan runs per billing month unless later overridden by an enterprise contract.

3. Payslip preview/download rule:

- All plans may preview payslips if the user has the correct role permission.
- No payslip can be downloaded for free.
- Every payslip download attempt must trigger a GBP 5 payment prompt.
- After successful GBP 5 payment, the requested payslip should download immediately or present a secure “Download now” button.
- Payment must be linked to company_id, user_id, employee_id, payslip_id, amount, Stripe reference and timestamp.
- Frontend checks are not enough. Backend must verify role permission, tenant access and paid entitlement before returning the file.
- Direct file URL or direct API bypass must be blocked.

4. UKVI Compliance Scanner:

- UKVI Compliance Scanner must be available on Starter, Professional and Enterprise plans.
- A company can run the scanner only 2 times per billing month.
- Show a usage meter in the UI, e.g. “1 of 2 scans used this billing month”.
- If the user attempts a third scan in the same billing month, block the scan and display a clear message.
- Every completed scan must generate a report that can be previewed and downloaded in both PDF and Word/DOCX format.
- Compliance gaps found by the scan should create alerts in the UKVI Compliance alerts area and/or dashboard alerts where applicable.
- Scanner usage and report downloads must be audit-logged.

5. Starter add-on/upgrade behaviour:

- Even though UKVI Compliance Scanner is enabled on Starter, Starter should still show a clear upgrade/add-on CTA that allows the user to move to Professional for the broader compliance package.
- Implement this as an upgrade-to-Professional flow rather than duplicate scanner entitlement.
- If an old standalone UKVI scanner add-on exists, audit it and migrate/remove it safely without breaking existing subscriptions.

AUDIT-FIRST REQUIREMENT

Before implementing, produce a short technical findings summary covering:

- Where plan prices and features are currently defined.
- Whether Stripe Products/Prices exist and whether they need to be updated or recreated.
- Existing subscription database schema and webhook handling.
- Existing feature gating system and whether it is enforced backend-side.
- Existing payslip preview/download routes and whether downloads can be bypassed.
- Existing UKVI Compliance Scanner routes, scan report generation and usage limits.
- Existing billing transaction history and audit logs.

- Gaps that must be fixed before production.

IMPLEMENTATION REQUIREMENTS

A. Billing/Plans

- Update plan configuration in backend, frontend and seed/migration files.
- Ensure Stripe price IDs are environment-specific and configurable through environment variables or secure config.
- Do not hard-code live Stripe secret keys.
- Show updated plan cards on the Billing page.
- Ensure the current plan card, subscription status and employee limit are accurate.

B. Feature Entitlements

- Implement or update a robust entitlement checker such as `canAccessFeature(companyId, featureKey)`, `getPlanLimits(companyId)`, and `enforceFeatureLimit(companyId, featureKey)`.
- Ensure feature gating is enforced on both UI and backend APIs.
- Add feature keys such as:
 - `ukvi_compliance_scanner`
 - `ukvi_report_download`
 - `payslip_preview`
 - `payslip_paid_download`
 - `payroll_processing`
 - `hmrc_rti`
 - `enterprise_multi_entity`
 - `enterprise_sso`

C. UKVI Scan Usage

- Track usage by company and billing period.
- Do not rely on calendar month if subscription billing periods exist; use subscription `current_period_start/current_period_end` when available.
- Add DB table/model if needed, such as `ukvi_scan_usage` with `company_id`, `period_start`, `period_end`, `scans_used`, `last_scan_at`.
- Increment usage only when a scan is actually started/completed according to consistent product logic.
- Prevent race conditions so two simultaneous clicks cannot exceed the limit.

D. Payslip Payment Workflow

- Add a secure paid-download flow:
 1. User clicks Download on a payslip.
 2. Backend validates tenant, permission and payslip existence.
 3. Backend creates Stripe Checkout Session or PaymentIntent for GBP 5.
 4. Stripe webhook confirms payment.
 5. Backend creates/updates a `payslip_download_payment` record.
 6. User is redirected back and download starts or secure download button appears.
- Backend download endpoint must check paid status before streaming or signing the file.
- Payment failure/cancel must not unlock download.
- Audit every download attempt, successful payment and successful download.

E. Report Downloads

- UKVI scan report must support PDF and DOCX download.
- Store report files securely and tenant-isolated.
- Only authorised users should preview or download reports.
- Report download actions must be audit-logged.

F. Security and Compliance

- Enforce role-based access control.

- Enforce tenant isolation everywhere.
- Verify Stripe webhooks using Stripe signature.
- Make webhook handlers idempotent.
- Store no card data locally.
- Ensure sensitive payslip/report files are never publicly exposed.
- Ensure test and live billing environments are separated.

G. Tests

Implement or update tests for:

- Correct display of new plan prices.
- Subscription creation/update for each plan.
- Entitlement logic for each plan.
- UKVI scanner available on all plans.
- UKVI scanner cannot run more than twice in a billing month.
- UKVI report preview and PDF/DOCX download.
- Payslip preview works without payment.
- Payslip download is blocked without GBP 5 payment.
- Successful payment unlocks immediate download.
- Cancelled/failed payment does not unlock download.
- Direct API/file download bypass fails without entitlement.
- Stripe webhook signature verification and idempotency.
- Tenant isolation: one company cannot access another company's payslips, payments, scans or reports.
- Role permissions: unauthorised staff cannot access payslip downloads or scanner/report actions.

DELIVERABLES

1. Audit findings summary.
2. Updated billing UI and backend logic.
3. Updated plan/feature configuration.
4. Stripe integration updates and webhook handling.
5. Payslip preview and GBP 5 pay-per-download workflow.
6. UKVI Compliance Scanner 2-runs-per-billing-month limit.
7. PDF/DOCX report download support.
8. Audit logs and transaction history updates.
9. Unit/integration tests and QA checklist.
10. Clear notes on environment variables and Stripe live-mode go-live steps.

ACCEPTANCE CRITERIA

- Billing page shows Starter GBP 29, Professional GBP 39, Enterprise GBP 129.
- UKVI Compliance Scanner is enabled on all plans with exactly 2 scans per billing month.
- Third scanner attempt is blocked and clearly explained.
- UKVI reports can be previewed and downloaded as Word/PDF.
- Payslip preview is free for authorised users.
- Payslip download requires GBP 5 payment and downloads immediately after confirmed payment.
- Backend prevents all unpaid direct download attempts.
- All actions are properly audit-logged.
- Tests pass and the implementation is production-ready.

15. Suggested QA Test Scenarios

Test Scenario	Expected Result
Starter subscribes	Starter plan is GBP 29/month and employee limit is

	10.
Professional subscribes	Professional plan is GBP 39/month and employee limit is 50.
Enterprise subscribes	Enterprise plan is GBP 129/month and employee limit is unlimited.
Starter runs first UKVI scan	Scan runs; usage becomes 1/2.
Starter runs second UKVI scan	Scan runs; usage becomes 2/2.
Starter attempts third scan	Blocked with clear limit message.
User previews payslip	Preview opens without payment.
User downloads payslip without payment	Blocked and prompted to pay GBP 5.
User pays GBP 5	Webhook confirms; secure download is enabled immediately.
Unauthorised user tries payslip download	Blocked even if they attempt direct URL.
Company A tries Company B payslip/report	Blocked by tenant isolation.

16. Developer Notes

- Use configuration-driven plans rather than duplicating plan data across the UI and backend.
- Stripe live prices should normally be new Price objects; existing Stripe Prices are usually not edited after creation.
- Keep test Stripe keys and live Stripe keys completely separate.
- Do not trust redirect success pages; only trusted webhooks should confirm payment.
- For scanner usage limits, use row locks/transactions or atomic updates to avoid double-click/race-condition abuse.
- The UI should clearly explain that payslip preview is free but download costs GBP 5.
- The product owner should decide whether one GBP 5 payment unlocks one immediate file download only or a time-limited re-download window. Implement the chosen policy explicitly.